

KOREA FSC · 망분리 완화 → 위험기반 MLS

망분리를 풀면, 신뢰를 무엇으로 대체하는가

MLS 보상통제를 **코드로** — 막는다는 사실을 매년 라이브로 재현.

문제

FSC 로드맵(2024-08-13): 위치 기반 분리 → 위험 기반 MLS.

- "내부망 = 신뢰"가 사라진다
- 그 자리를 보상통제로 메워야 한다
- 핵심: 그 통제가 **실제로 막는지**를 무엇으로 증명하나 — 슬라이드가 아니라 **실행·검증**

접근 — 한 워크로드, 6개 통제 계층

identity → segmentation → authz → encrypt → runtime

- ① **신원** admission · SA-use · SPIFFE
- ② **세분화** Cilium L3/L7 default-deny
- ③ **인가** Cedar per-request (owner·한도·역할·동결)
- ④ **egress** / ⑤⑥ **암호화** / ⑦ **런타임** — 유출 차단 · WireGuard·etcd · Tetragon exec SIGKILL(zero-exec)

각 계층은 **재실행 가능한 테스트**에 묶인다.

증거 — 전부 재현 가능

metric		
coverage	검증가능-as-code	82.5% (33/40)
verify	라이브, 전 계층	21/21
cedar	인가 + 에이전트 위임	8/8 · 17/17
rebac	OpenFGA 관계	11/11
checkov	shift-left · 실 CVE 포착	452 / 0

// 21/21은 기능 회귀 스위트(분모 없음) · 갭 17.5%(CONFIGURED 3 · GOVERNANCE 2 · NOT-COVERED 4)는 행 단위 공개

82.5%는 어떻게 — 정직하게만

숫자는 라이브 테스트로만 올린다 · 못 버는 건 정직하게 남긴다

- **SL2** 시크릿스캔 → **VERIFIED** · 심은 시크릿을 잡는 게이트를 CI에서 라이브 증명
- **NS5** cross-ns → **VERIFIED** · 외부 네임스페이스에서 db·api 차단을 CI에서 라이브 증명
- **ID4** mutual-auth → CONFIGURED 유지 · 내 과대주장을 찾아 정정(SVID는 SA-암호가 아니라 라벨 기반)
- **ED3** broader-runtime → NOT_COVERED 유지 · bpf-LSM 부재를 CI에서 라이브 확정

// 77.5% → 82.5%: 오른 두 칸은 라이브 증명, 안 오른 두 칸은 왜 못 버는지까지 행에 기록

"아하" — 같은 경로, 다른 신원

alice GET acct-alice 200

bob 같은 경로 403

같은 네트워크 경로·같은 L7 허용이라도 **principal이 다르면 결과가 다르다.**

거친 통제(세분화) → 세밀한 통제(per-request)를 순서대로 통과해야 데이터에 닿는다.

왜 신뢰할 수 있나

"안전하다"가 아니라 — **갭을 공개한다.**

- **재현 증거** — 감사자가 부작용 없는 dry-run으로 직접 확인
- **명시된 갭** — 미검증 17.5%를 행 단위로 공개
- **정직성** — 요청자 JWT 행을 증명 전엔 CONFIGURED로 낮춰 뒀다가 라이브로 강제를 증명해 VERIFIED로 올렸다 (편한 숫자가 아니라 참값)
- **적대적 자기검증** — 내 정책의 실 결함·과대주장을 스스로 찾아 수정(SA-use CRITICAL · mutual-auth가 위조를 닫는다는 과대주장)

라이브 데모 (5분, 그대로 실행)

\$ bash scripts/verify.sh → 21/21 PASS

forged app:api on web-sa → DENY

db: /bin/sh 137 db: id 137 (zero-exec)

etcd raw → k8s:enc:aescbc:v1: (평문 0)

도입

자가채점 재구현 트랙 · 무클러스터 랩은 Codespaces 0설치 · MIT · 당신의 인프라

**망분리 완화는 규제 완화가
아니라 신뢰 모델의 교체다.**